

Requerimientos Funcionales y No Funcionales – Sistema de Autenticación Centralizado SSO

Ministerio de Educación, Deporte y Cultura (MINEDEC)

ALTIUS
PTC-MINEDEC-#

2026

Control del documento

Documento: Especificación de requerimientos funcionales y no funcionales — Componente C2 (Subcomponentes C2.2 y C2.3)

Versión: ~~0.3 — ajustada a la reunión del 22 de septiembre y al TDR definitivo~~ 0.4 — ajustada al Documento de Arquitectura de Solución SSO, para validación de MINEDEC

Fecha: ~~24 de septiembre de 2026~~ 13 de octubre de 2026

Insumos: Términos de Referencia definitivos (Régimen Especial), versión 0.2 de este documento, reunión de definición con la Coordinación General de TIC del 22 de septiembre de 2026, Entregable 1 (Objetivos SSO), Entregable 2 (Arquitectura de Gestión de Identidad) y reunión de levantamiento inicial con MINEDEC, y Documento de Arquitectura de Solución SSO (13 de octubre de 2026)

Versión	Fecha	Descripción
0.1	10 de septiembre de 2026	Versión inicial. Consolida los objetivos y la arquitectura aprobados con las necesidades levantadas en la reunión con el equipo de TIC del MINEDEC.
0.2	22 de septiembre de 2026	Alineación con los entregables del TDR para los subcomponentes C2.2 y C2.3. Se retiran los requerimientos fuera de alcance y se reclasifican a F1 los que el TDR exige en C2.2.
0.3	23 de septiembre de 2026	Incorpora las definiciones de la reunión del 22 de septiembre y el TDR definitivo: se descarta Active Directory, se reincorpora el sistema centralizado de permisos y la identidad única por cédula y/o identificador único para los usuarios sin cédula, y se actualizan brechas y decisiones. 23 requerimientos ajustados, 15 reincorporados, 2 nuevos y 7 retirados. El detalle está en el Anexo B.
0.4	13 de octubre de 2026	Alinea los requerimientos con el Documento de Arquitectura de Solución SSO: patrones de integración (nativo y perimetral), OIDC como protocolo principal, identidad por cédula devuelta por Sistema de Autenticación Centralizado SSO, solo lectura sobre Workspace, cierre de sesión por revalidación, publicación desde la consola y red. 25 requerimientos ajustados, 6 nuevos y 1 retirado; D-04 y D-05 resueltas y 6 decisiones nuevas. El detalle está en el Anexo B.

Contenido

Control del documento **2**
Contenido **3**
1. Introducción **4**
1.1 Propósito 4
1.2 Alcance 4
1.3 Fuentes de información 4
1.4 Convenciones 5
2. Contexto y situación actual **6**
2.1 Actores y poblaciones 6
3. Requerimientos funcionales **8**
3.1 Gestión de Identidades y Ciclo de Vida 8
3.2 Autenticación y Single Sign-On 10
3.3 Autorización, Roles y Permisos 13
3.4 Usuarios Externos (Ciudadanos) 16
3.5 Administración Delegada y Autoservicio 17
3.6 Integración de Aplicaciones 19
3.7 Auditoría, Trazabilidad y Control 20
4. Requerimientos no funcionales **23**
4.1 Seguridad 23
4.2 Rendimiento y escalabilidad 24
4.3 Disponibilidad y continuidad 25
4.4 Interoperabilidad y estándares 26
4.5 Usabilidad y accesibilidad 26
4.6 Operación y observabilidad 27
4.7 Mantenibilidad y evolución 28
4.8 Cumplimiento normativo 29
5. Brechas identificadas y decisiones **30**
5.1 Brechas 30
5.2 Decisiones pendientes del Ministerio 32
5.3 Definiciones resueltas en la reunión del 22 de septiembre 33
6. Resumen de la línea base **35**
6.1 Próximos pasos 35

1. Introducción

1.1 Propósito

Este documento define los requerimientos funcionales y no funcionales del sistema de autenticación centralizado SSO y de la gestión centralizada de accesos del Ministerio de Educación, Deporte y Cultura, delimitados al alcance contractual de los subcomponentes C2.2 (Implementación del Sistema de Autenticación Centralizado SSO) y C2.3 (Integración de dos aplicaciones legadas) de los Términos de Referencia. Es un documento vivo y sirve de línea base para el Documento de Análisis Funcional, el diseño detallado, la construcción y las pruebas.

1.2 Alcance

El alcance cubre la configuración de Google Cloud Identity como proveedor central de identidad y única fuente de verdad para usuarios internos (administrativos, docentes y estudiantes) y externos (ciudadanos); la autenticación multifactor; las políticas de acceso y sesión; la recuperación de contraseñas desde Google Workspace; ~~el SSO sobre SAML 2.0 y OpenID Connect con un componente SP/RP reutilizable~~ el SSO con OpenID Connect como protocolo principal y SAML 2.0 como alternativo, con un componente SP/RP reutilizable (paquete estándar de integración); un sistema centralizado de permisos (Sistema de Autenticación Centralizado SSO), con repositorio propio, para registrar activos tecnológicos, tipos de usuario, roles, perfiles y permisos con administración delegada por aplicativo; la consola de administración, incluida la publicación de aplicaciones; la auditoría y la trazabilidad; la seguridad; las pruebas; la puesta en producción con CI/CD e infraestructura como código; y la integración de dos aplicaciones legadas.

Quedan fuera de esta línea base:

- La sincronización con Active Directory y la gestión de dispositivos. El AD se conserva solo para el inicio de sesión Windows del personal administrativo, sin relación con el SSO.
- Los flujos de solicitud y aprobación de accesos, la segregación de funciones, la recertificación y el motor de reglas de negocio, cuyo diseño corresponde al Documento de Arquitectura IAM-SSO del subcomponente C2.1.
- La integración con fuentes estatales de validación (DINARDAP, Registro Civil, SENESCYT, SRI).
- El aprovisionamiento de cuentas de estudiantes desde la matrícula, la Landing Page y los datos de autorrecuperación de contraseña de estudiantes, que corresponden a los subcomponentes C1.3 y C1.4.
- La migración de cuentas de Microsoft 365 a Google y la integración con Talento Humano, forman parte de la visión futura del Ministerio.

1.3 Fuentes de información

- **Términos de Referencia definitivos — Componente C2.** Especificaciones técnicas de los subcomponentes C2.2 y C2.3, y de los subcomponentes C1.3 y C1.4 con los que se relaciona.
- **Reunión de definición del 22 de septiembre de 2026.** Sesión con la Coordinación General de TIC (Administrador, Infraestructura y Desarrollo) en la que se aclararon la arquitectura de identidad, el modelo de permisos, los usuarios externos y los costos.
- **Entregable 1 — Objetivos de la Implementación de Single Sign-On.** Objetivos principales y secundarios, consideraciones clave y delimitación del alcance.

- **Entregable 2 — Arquitectura para la Gestión de Identidad MINEDEC (v0.2).** Flujos de autenticación y patrones de integración. Su modelo híbrido con Active Directory queda superado por la reunión del 22 de septiembre.
- **Reunión de levantamiento inicial con el equipo de TIC del MINEDEC.** Necesidad funcional expresada por el Ministerio.
- Documento de Arquitectura de Solución SSO (13 de octubre de 2026). Patrones de integración, contrato de autorización, red, publicación de aplicaciones e infraestructura; sus hallazgos motivan los cambios de esta versión (Anexo B).

1.4 Convenciones

Cada requerimiento conserva el código asignado en la versión 0.1 para mantener la trazabilidad; por eso la numeración presenta saltos. Los requerimientos nuevos reciben el siguiente código libre de su dominio. La prioridad sigue la clasificación MoSCoW, expresada en español:

Prioridad	Significado
Debe tener	Indispensable. Sin este requerimiento la solución no cumple su objetivo ni puede pasar a producción.
Debería tener	Importante. Aporta valor sustantivo y debe implementarse salvo restricción justificada.
Podría tener	Deseable. Se implementa si el esfuerzo y el calendario lo permiten.

La columna Subcomp. indica el subcomponente del TDR que materializa cada requerimiento funcional: C2.2 (plataforma SSO y gestión de accesos), C2.3 (integración de las dos aplicaciones legadas) o ambos. Los cambios de esta versión respecto de la anterior se detallan en el Anexo B.

2. Contexto y situación actual

El Ministerio administra cerca de 170 aplicativos con tres mecanismos de autenticación coexistentes: aplicaciones que validan contra el Active Directory institucional, aplicaciones con tabla propia de usuarios y contraseñas, y aplicaciones integradas al sistema de seguridades vigente. Los sistemas incorporados con la fusión de Educación Superior, Deporte y Cultura tampoco están conectados a ese sistema de seguridades.

Hoy coexisten dos dominios. En el Active Directory está el dominio educacion.gob.ec, con cuentas de Microsoft 365 para estudiantes, docentes y personal administrativo. En Google está el dominio minedec.gob.ec, con cuentas creadas de forma independiente como parte del plan de migración de Microsoft 365 a Google. El personal administrativo seguirá desbloqueando su equipo Windows con la credencial del AD. Los dominios definitivos de cada población en Google y su organización en uno o varios tenants están por definir (D-21).

En la reunión del 22 de septiembre, MINEDEC ratificó que descartó la arquitectura híbrida con Active Directory, porque la sincronización es unidireccional y obliga a mantener dos contraseñas. Cloud Identity es la única fuente de verdad del SSO, y la gestión de dispositivos queda fuera de esta iniciativa.

La necesidad central del Ministerio es un sistema centralizado que permita al Administrador de la plataforma registrar los activos tecnológicos con sus enlaces, tipos de usuario, roles y perfiles; delegar la administración de cada aplicativo en su área dueña para no convertirse en cuello de botella; y controlar el acceso con trazabilidad completa. El universo principal es la comunidad: el ciudadano que se inscribe, postula, resulta beneficiario y cierra un proceso, y que a lo largo de su vida puede ser estudiante, docente, funcionario y postulante, todo bajo una única identidad asociada a su cédula.

Un proveedor anterior desarrolló un conector que vincula el número de cédula con la cuenta de Google y avanzó en el diseño de un módulo autorizador que nunca se probó. MINEDEC solicitará formalmente a las áreas, mediante memorando, el detalle de los aplicativos que gestionan y de sus tipos de usuario, roles y perfiles. Existe además un levantamiento previo de entre 70 y 80 tipos de usuario ligados a la normativa, que el Ministerio considera incompleto.

2.1 Actores y poblaciones

Tipo de usuario	Descripción	Volumen aproximado
Administrativo	Personal de planta central y unidades administrativas, con cuenta Google institucional.	10.000
Docente	Docentes de instituciones educativas, con cuenta Google institucional.	160.000
Estudiante	Población estudiantil, en su mayoría menor de edad. Cuentas aprovisionadas desde la matrícula (C1.4).	≈ 2,1 millones
Externo — ciudadano	Personas que interactúan con los servicios del Ministerio, con tipos y subtipos: inscritos, postulantes y beneficiarios de becas, aspirantes a concursos, deportistas, actores culturales, entre otros.	Por dimensionar (p. ej. 76.000 aspirantes en la última convocatoria de becas)

Tipo de usuario	Descripción	Volumen aproximado
Representante de organización	Persona que actúa en nombre de una organización, por ejemplo un patrocinador de deportistas. Se identifica con su cédula y se vincula al RUC de la organización.	Por confirmar
Administrador de aplicativo	Director o delegado del área dueña de un aplicativo, ~~que gestiona sus usuarios, roles y perfiles~~ que gestiona los roles, perfiles y permisos de su aplicativo.	Uno o más por aplicativo
Superadministrador	Responsable del gobierno de la plataforma y de crear los administradores de cada aplicativo, y de registrar y publicar los aplicativos.	Equipo reducido

Volúmenes internos tomados del TDR definitivo; los de usuarios externos deben ser confirmados formalmente por el Ministerio antes del dimensionamiento definitivo.

3. Requerimientos funcionales

Se definen ~~61~~ 63 requerimientos funcionales agrupados en siete dominios.

3.1 Gestión de Identidades y Ciclo de Vida

Código	Requerimiento	Prioridad	Subcomp.
RF-GI-01	**Repositorio central de identidades** Google Cloud Identity debe constituirse en el Proveedor de Identidad (IdP) central y única fuente de verdad para la autenticación de todos los tipos de usuario del Ministerio, ~~sobre el dominio institucional de Google (minedec.gob.ec)~~ sobre los dominios institucionales de Google Workspace (estudiante.edu.ec y los de docentes y administrativos, por definir en D-21). El SSO no depende de Active Directory. **Criterio de aceptación:** Existe un único IdP configurado; toda aplicación integrada delega la autenticación en él y ninguna mantiene almacén de credenciales propio. **Fuente:** *Entregable 1 · Entregable 2 · Reunión 22-sep*	Debe tener	C2.2
RF-GI-03	**Identidades internas nativas en la nube** Los usuarios administrativos (~10.000), docentes (~160.000) y estudiantes (~2,1 millones) deben gestionarse directamente en Google Cloud Identity, sin dependencia de Active Directory. El aprovisionamiento de estudiantes proviene de las APIs de matrícula del subcomponente C1.4; el SSO las consume como fuente. **Criterio de aceptación:** Existen OUs y procesos de aprovisionamiento diferenciados por tipo de usuario interno que no requieren objeto en AD. **Fuente:** *Reunión · Reunión 22-sep · TDR C1.4*	Debe tener	C2.2
RF-GI-05	**Gestión del ciclo de vida (altas, bajas y cambios)** El sistema debe soportar el ciclo completo de vida de la identidad: alta, modificación de atributos, traslado organizacional, suspensión y baja, originado en la fuente autoritativa de cada tipo de usuario (matrícula para estudiantes, bases de datos de usuarios para administrativos y docentes). La salida de una etapa da de baja el perfil correspondiente, no la identidad de la persona. **Criterio de aceptación:** Cada evento del ciclo de vida ~~se propaga a Cloud Identity y al sistema de permisos~~ se registra en Cloud Identity (por C1.4 o por los administradores del MINEDEC) y Sistema de Autenticación Centralizado SSO lo sincroniza en modo de solo lectura, y queda registrado en la pista de auditoría; la identidad persiste aunque se den de baja sus perfiles. **Fuente:** *Reunión · Reunión 22-sep*	Debe tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-GI-06	**Desprovisionamiento oportuno ante desvinculación** La baja de un funcionario o docente debe revocar su acceso a todas las aplicaciones federadas dentro de la ventana de tiempo acordada, sin intervención manual en cada sistema. **Criterio de aceptación:** Ante una baja en la fuente autoritativa, la cuenta queda suspendida y las sesiones activas invalidadas dentro del SLA definido (por acordar con MINEDEC). En Sistema de Autenticación Centralizado SSO, la revocación es efectiva en 300 segundos o menos. **Fuente:** *Reunión*	Debe tener	C2.2
RF-GI-07	**Suspensión en lugar de eliminación** Las cuentas que dejan de estar vigentes deben suspenderse y no eliminarse, preservando correos, archivos en Drive y evidencia para transferencia o cumplimiento. **Criterio de aceptación:** La política de suspensión está configurada en Cloud Identity; se documenta el procedimiento de eliminación lógica definitiva (manteniendo la trazabilidad histórica) y su ventana de recuperación de 20 días. **Fuente:** *Entregable 2*	Debe tener	C2.2
RF-GI-09	**Identidad persistente y trazabilidad multi-rol** Una misma persona natural debe conservar un identificador único y permanente (número de cédula y/o identificador único) a lo largo de todos los roles que asuma en el tiempo —ciudadano, postulante, becario, docente, funcionario entre otros— aunque cambie de cuenta o de dominio de correo. **Criterio de aceptación:** Dado un número de cédula, el sistema devuelve el histórico completo de identidades, cuentas y roles asociados a esa persona, con fechas de vigencia. **Fuente:** *Reunión (brecha) · Reunión 22-sep*	Debe tener	C2.2
RF-GI-10	**Convivencia de múltiples cuentas por persona** El sistema debe permitir que una misma persona tenga simultáneamente una identidad externa (ciudadano) y una o más cuentas internas o de correo, vinculadas explícitamente a su única identificación, conforme al mecanismo de vinculación que se defina. **Criterio de aceptación:** Un usuario con cuenta ciudadana y cuenta institucional accede a los sistemas correspondientes a cada perfil; el vínculo entre ambas es consultable y auditable. **Fuente:** *Reunión (brecha) · Reunión 22-sep*	Debe tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-GI-11	**Esquema de atributos extendido** Debe definirse un esquema de atributos personalizados en Cloud Identity que preserve, como mínimo: número de identificación (cédula, pasaporte o código asignado por MINEDEC), tipo y subtipo de usuario, unidad organizacional e institución de adscripción así como atributos que permitan tanto la identificación como la clasificación según sus roles y perfiles. Los datos de autorización se gestionan en el repositorio independiente del sistema de permisos. **Criterio de aceptación:** El esquema personalizado está creado y poblado por los procesos de aprovisionamiento; ~~la identificación viaja en los claims SAML/OIDC hacia las aplicaciones~~ Sistema de Autenticación Centralizado SSO devuelve la identificación a las aplicaciones en la respuesta de /api/v1/authorize y en las cabeceras X-Minedec-*; el inicio de sesión se hace con el correo. **Fuente:** *Entregable 2 · Reunión 22-sep*	Debe tener	C2.2
RF-GI-12	**Identificador maestro y control de unicidad** El número de cédula (o, en su defecto, pasaporte o código asignado por MINEDEC) debe operar como clave natural de la persona; el usuario es la identificación, no el correo electrónico. El sistema debe validar el número de cédula o el código único definido en conjunto con el MINEDEC con su algoritmo verificador. **Criterio de aceptación:** Una cédula con dígito verificador inválido se rechaza; al intentar crear una identidad con una identificación existente, el proceso la rechaza, informa el motivo y lo registra en la pista de auditoría. **Fuente:** *Reunión · Reunión 22-sep*	Debe tener	C2.2
RF-GI-13	**Estructura organizacional multi-institución** La estructura de Unidades Organizativas y grupos debe modelar el Ministerio fusionado (Educación, Educación Superior, Deporte y Cultura) y no depender de la dimensión «sede» del sistema actual. Las OUs se usan para las políticas de Google; el ámbito de autorización se resuelve con atributos (institución, zona, distrito, cartera y tipo de usuario) en Sistema de Autenticación Centralizado SSO (D-05). **Criterio de aceptación:** La jerarquía de OUs soporta las cuatro carteras y permite aplicar políticas diferenciadas por institución sin modificar el modelo de datos. El ámbito de acceso se expresa con atributos, sin la dimensión «sede». **Fuente:** *Reunión (brecha)*	Debe tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-GI-15	**Identificador alternativo para personas sin cédula** El sistema debe admitir personas que no cuentan con cédula —por ejemplo estudiantes extranjeros o menores sin documento— mediante el código de identificación asignado por MINEDEC, y soportar su actualización uno a uno a la cédula cuando la persona la obtenga, sin perder el histórico. **Criterio de aceptación:** Se registra una persona con código MINEDEC y, al actualizarse a cédula, conserva sus cuentas, perfiles y trazabilidad. **Fuente:** *Reunión 22-sep*	Debe tener	C2.2

3.2 Autenticación y Single Sign-On

Código	Requerimiento	Prioridad	Subcomp.
RF-AUT-01	**Inicio de sesión único con cuenta Google institucional** El usuario interno debe autenticarse una sola vez ~~con su cuenta Google institucional (minedec.gob.ec)~~ con su cuenta Google institucional (dominios definidos en D-21) y acceder a todas las aplicaciones federadas sin volver a ingresar credenciales. **Criterio de aceptación:** Autenticado en el IdP, el usuario accede a al menos dos aplicaciones federadas sin nuevo ingreso de credenciales. **Fuente:** *Entregable 1 · Reunión*	Debe tener	C2.2
RF-AUT-02	**Flujo iniciado por el Proveedor de Servicios (SP-initiated)** La aplicación debe detectar la ausencia de sesión, construir la solicitud de autenticación y redirigir al IdP, ~~procesando luego la aserción recibida en su ACS URL~~ procesando luego la aserción SAML en su ACS URL o el código de autorización OIDC en su URI de redirección. **Criterio de aceptación:** El flujo completo SP-initiated se ejecuta y valida firma, emisor y audiencia de la aserción (o del ID Token) antes de crear la sesión local. **Fuente:** *Entregable 2*	Debe tener	C2.2 · C2.3
RF-AUT-03	**Flujo iniciado por el Proveedor de Identidad (IdP-initiated)** Desde el portal o lanzador de aplicaciones de Google, el usuario debe poder seleccionar una aplicación federada e ingresar directamente a ella. **Criterio de aceptación:** Desde el lanzador de aplicaciones, el clic sobre una aplicación federada abre una sesión válida en dicha aplicación. **Fuente:** *Entregable 2*	Debería tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-AUT-04	**Soporte de SAML 2.0** El IdP debe emitir aserciones SAML 2.0 firmadas digitalmente, con los atributos e identificador de usuario acordados por aplicación. **Criterio de aceptación:** Se valida contra al menos una aplicación legada refactorizada; ~~la aserción incluye NameID y los claims configurados~~ la respuesta y la aserción están firmadas, el NameID es el correo primario y no se incluyen roles: la autorización se consulta a Sistema de Autenticación Centralizado SSO. **Fuente:** *Entregable 2*	Debe tener	C2.2
RF-AUT-05	**Soporte de OpenID Connect / OAuth 2.0** El IdP debe soportar ~~el flujo de código de autorización de OIDC~~ el flujo Authorization Code con PKCE (S256) de OIDC, único flujo permitido y protocolo principal de integración, para aplicaciones modernas, APIs y clientes móviles. **Criterio de aceptación:** Una aplicación cliente intercambia el código por ID Token y Access Token por canal posterior y valida el ID Token. **Fuente:** *Entregable 2*	Debe tener	C2.2
RF-AUT-06	**Cierre de sesión único (Single Logout)** El cierre de sesión en una aplicación debe invalidar la sesión local ~~y notificar al IdP para el cierre de la sesión global~~ y forzar que el siguiente acceso se revalide; Google Cloud Identity no implementa el cierre de sesión único (no procesa LogoutRequest de SAML ni publica un endpoint de cierre de sesión OIDC), por lo que el cierre coordinado se resuelve con revalidación contra Sistema de Autenticación Centralizado SSO, en las aplicaciones donde se determine su aplicabilidad junto con el Administrador del contrato. **Criterio de aceptación:** ~~Tras el logout, el intento de acceso a otra aplicación federada exige nueva autenticación.~~ Tras el cierre de sesión, la aplicación invalida su sesión local, y una revocación en Sistema de Autenticación Centralizado SSO se aplica en todas las aplicaciones en 300 segundos o menos. **Fuente:** *Entregable 2 · TDR C2.2*	Debe tener	C2.2
RF-AUT-07	**Autenticación multifactor centralizada** El sistema debe exigir un segundo factor de autenticación, configurado y aplicado de forma centralizada desde la consola de administración, sin configuración por aplicación. **Criterio de aceptación:** La política de MFA se define por OU o grupo y se aplica de manera consistente a todas las aplicaciones federadas. **Fuente:** *Reunión · Entregable 1 · Entregable 2*	Debe tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-AUT-08	**Métodos de segundo factor soportados** Deben habilitarse, como mínimo: notificación push (Google Prompt), aplicación de códigos temporales (TOTP), llaves de seguridad FIDO2/WebAuthn y códigos de respaldo. **Criterio de aceptación:** Cada usuario puede registrar al menos un método principal y un método de respaldo; se documenta el procedimiento de recuperación. **Fuente:** *Entregable 2 · Reunión*	Debe tener	C2.2
RF-AUT-09	**Despliegue por fases del segundo factor** La exigencia de MFA debe poder activarse gradualmente: piloto de TI y administradores, luego personal administrativo, luego docentes y finalmente estudiantes. **Criterio de aceptación:** La política se activa por OU sin afectar a las poblaciones aún no incluidas; existe un plan de despliegue por fases. **Fuente:** *Entregable 2*	Debería tener	C2.2
RF-AUT-10	**Políticas de sesión** Deben ser configurables la duración máxima de sesión, el cierre por inactividad, la re-autenticación para operaciones sensibles y el control de sesiones concurrentes. **Criterio de aceptación:** Los parámetros de sesión se configuran centralmente y se validan en pruebas para cada tipo de usuario. **Fuente:** *Derivado · TDR C2.2*	Debe tener	C2.2
RF-AUT-11	**Autenticación de usuarios externos** Los ciudadanos deben poder autenticarse sin una cuenta institucional del dominio, usando su número de identificación como usuario (no el correo) y un mecanismo definido y seguro. La pantalla de acceso debe diferenciar el ingreso de usuarios internos (cuenta Google institucional) del de usuarios externos (identificación). **Criterio de aceptación:** Un ciudadano se registra y autentica con su identificación para acceder a un trámite sin que se le cree ni licencie una cuenta de Google Workspace. **Fuente:** *Reunión · TDR C2.2 · Reunión 22-sep*	Debe tener	C2.2
RF-AUT-12	**Detección y bloqueo de acceso sospechoso** El sistema debe detectar y responder a intentos fallidos reiterados, accesos desde ubicaciones o dispositivos inusuales e indicios de toma de cuenta. **Criterio de aceptación:** Se configuran reglas de bloqueo y alerta; los eventos quedan registrados y son consultables. **Fuente:** *Derivado · TDR C2.2*	Debería tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-AUT-13	**Recuperación de contraseñas y credenciales** El usuario debe poder recuperar el acceso y restablecer su contraseña o segundo factor por un canal autenticado, sin depender de la mesa de servicio. Para estudiantes, se apoya en los datos de recuperación (correo y teléfono) que registran los subcomponentes C1.3 y C1.4; para usuarios externos, en el mecanismo de identidad ciudadana que se defina. **Criterio de aceptación:** El flujo de recuperación se completa sin intervención de un administrador y queda auditado. **Fuente:** *Derivado · TDR C2.2 · TDR C1.3 · Reunión 22-sep*	Debe tener	C2.2

3.3 Autorización, Roles y Permisos

Conforme a lo acordado en la reunión del 22 de septiembre, roles, perfiles y permisos se gestionan en un sistema centralizado con repositorio propio, independiente de Cloud Identity, que solo toma de este la identidad autenticada y la identificación (por ejemplo, la cédula), a través de ese identificador, se hace la validación interna de roles, permisos y accesos a los sistemas en el dicho repositorio propio, por ende, como módulo, no depende de Cloud Identity, pero sí es Cloud Identity, quien a través de la autorización, resuelve la identidad de la persona a autorizar. Quedan fuera los flujos de solicitud y aprobación, la segregación de funciones, la recertificación y el motor de reglas de negocio, cuyo diseño se aborda en el Documento de Arquitectura IAM-SSO del subcomponente C2.1.

Código	Requerimiento	Prioridad	Subcomp.
RF-AUZ-01	**Sistema centralizado de permisos desacoplado del IdP** La gestión de roles, perfiles y permisos debe residir en un sistema centralizado con repositorio propio, independiente de Cloud Identity, que solo toma de este la identidad autenticada y la identificación. Las aplicaciones consultan sus permisos sin acoplar su código al mecanismo de autenticación. **Criterio de aceptación:** La aplicación integrada obtiene su autorización por interfaz definida desde el repositorio del sistema de permisos, sin lógica de identidad embebida. **Fuente:** *Entregable 2 · Reunión · Reunión 22-sep*	Debe tener	C2.2
RF-AUZ-02	**Modelo de autorización flexible** El modelo debe combinar roles (RBAC) con atributos de identidad (ABAC) y permitir parametrizar nuevos tipos de usuario, aplicaciones y dimensiones organizacionales sin rediseño, superando el esquema fijo de usuario, sede, aplicación y rol del sistema de seguridades actual. **Criterio de aceptación:** El modelo se valida contra al menos tres casos de negocio reales del Ministerio sin requerir la dimensión «sede» y expresando el ámbito con atributos (D-05). **Fuente:** *Reunión (brecha) · Entregable 2 · Reunión 22-sep*	Debe tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-AUZ-03	**Registro de activos tecnológicos** El superadministrador debe poder registrar cada aplicativo o activo tecnológico del Ministerio con su enlace (URL), su configuración de federación (SAML 2.0 u OIDC), su patrón de integración (nativo o perimetral), su catálogo de rutas, sus tipos de usuario, roles y perfiles, y activarlo, publicándolo desde la consola (RF-ADM-08), cuando esté listo para operar. **Criterio de aceptación:** Se registra un aplicativo nuevo, se configuran sus roles y perfiles y queda disponible para SSO al activarlo, sin desarrollo adicional; en el patrón 2, tras completar los pasos externos guiados. **Fuente:** *Reunión · TDR C2.2 · Reunión 22-sep*	Debe tener	C2.2
RF-AUZ-04	**Definición de roles y perfiles por aplicación** Cada aplicativo registrado debe permitir la definición de sus propios roles y perfiles, con nombre, descripción y vigencia, gestionados en el sistema de permisos y disponibles para la aplicación por consulta ~~o en los claims de la aserción~~ a /api/v1/authorize o en las cabeceras X-Minedec-* del patrón 2; no viajan en la aserción. **Criterio de aceptación:** Se crean, modifican y desactivan roles y perfiles desde la consola sin intervención en base de datos. **Fuente:** *Reunión · TDR C2.2*	Debe tener	C2.2
RF-AUZ-05	**Definición de permisos granulares y perfiles** Deben definirse permisos atómicos (lectura, escritura, aprobación, eliminación y los que el negocio requiera) y componerse en perfiles asignables. **Criterio de aceptación:** Un perfil compuesto por permisos atómicos se asigna a un usuario y la aplicación respeta exactamente ese alcance. **Fuente:** *Reunión*	Debe tener	C2.2
RF-AUZ-06	**Asignación de roles y perfiles a identidades** El administrador debe poder seleccionar identidades internas o externas y asignarles perfiles sobre uno o varios aplicativos. **Criterio de aceptación:** La asignación se refleja en el siguiente inicio de sesión del usuario y queda auditada con su autor. **Fuente:** *Reunión · TDR C2.2*	Debe tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-AUZ-07	**Superadministración y administración delegada por aplicativo** El área de Administrador debe operar como superadministradora de la plataforma y poder crear, para cada aplicativo, uno o más administradores funcionales (director o delegado del área dueña), que gestionen usuarios, roles y perfiles exclusivamente dentro de su aplicativo. **Criterio de aceptación:** El superadministrador crea el administrador de un aplicativo; ese administrador gestiona su aplicativo y no puede ver ni modificar la configuración de otro. **Fuente:** *Reunión · Reunión 22-sep*	Debe tener	C2.2
RF-AUZ-10	**Vigencia y baja de perfiles** Debe ser posible otorgar perfiles con fecha de inicio y expiración que se revoquen automáticamente al vencer, y dar de baja un perfil cuando la persona sale de la etapa que lo justificaba, sin afectar su identidad ni sus otros perfiles. **Criterio de aceptación:** Un perfil con vigencia definida deja de ser efectivo en la fecha de corte sin acción manual, y la baja de un perfil no elimina la identidad. **Fuente:** *Entregable 1 · Reunión · Reunión 22-sep*	Debería tener	C2.2
RF-AUZ-12	**Interfaz de consulta de autorización** Las aplicaciones integradas deben poder consultar, por interfaz o API, los roles y permisos efectivos del usuario autenticado, reemplazando su lógica de autenticación propia. Cada aplicación se autentica ante Sistema de Autenticación Centralizado SSO con su propia credencial (OAuth 2.0 client credentials), y el PEP con una credencial de plataforma. **Criterio de aceptación:** La aplicación piloto obtiene roles y permisos por API y elimina su tabla local de usuarios y contraseñas. **Fuente:** *Reunión · Reunión 22-sep*	Debe tener	C2.2 · C2.3
RF-AUZ-13	~~**Propagación de roles y grupos en los claims**~~ **Entrega de identidad y permisos a la aplicación** ~~La pertenencia a grupos y los atributos relevantes de autorización deben poder viajar en la aserción SAML o en el ID Token de OIDC.~~ La identidad, los roles y el ámbito del usuario deben llegar a la aplicación sin depender de la aserción: en el patrón 1, por la respuesta de /api/v1/authorize; en el patrón 2, en las cabeceras X-Minedec-* que inyecta el PEP, con una aserción firmada por Sistema de Autenticación Centralizado SSO (X-Minedec-Assertion). **Criterio de aceptación:** ~~La aserción incluye el claim de grupos y la aplicación lo consume para su control de acceso.~~ La aplicación obtiene los roles y el ámbito por /api/v1/authorize o por las cabeceras, y la aserción de Google no incluye roles. **Fuente:** *Entregable 2*	Debe tener	C2.2 · C2.3

Código	Requerimiento	Prioridad	Subcomp.
RF-AUZ-16	**Catálogo de tipos de usuario con sustento normativo** El sistema debe mantener un catálogo parametrizable de tipos y subtipos de usuario (internos y externos), cada uno asociado a su sustento normativo o de negocio, a los atributos mínimos que exige su creación, a los requisitos para obtener cada rol y a las condiciones de su baja, según lo definan las unidades de negocio. **Criterio de aceptación:** Se crea un tipo de usuario nuevo con sus atributos obligatorios y reglas de alta y baja sin desarrollo adicional; no es posible crear un usuario de ese tipo sin los atributos definidos. **Fuente:** *Reunión 22-sep*	Debe tener	C2.2
RF-AUZ-17	**Catálogo de rutas por aplicación** Cada aplicación del patrón 2 debe tener un catálogo de rutas con una regla por defecto (autenticada, protegida o pública) y excepciones por ruta exacta, prefijo o extensión, donde gana la más específica. Antes de comparar, la ruta se normaliza automáticamente y las rutas ambiguas se rechazan. **Criterio de aceptación:** Una ruta pública se sirve sin inicio de sesión, una protegida solo con el permiso asignado, y una ruta codificada para evadir una regla (por ejemplo, con %2F o «..») se rechaza o se evalúa con la regla correcta. **Fuente:** *Documento de Arquitectura de Solución SSO (5.1.4)*	Debe tener	C2.2 · C2.3

3.4 Usuarios Externos (Ciudadanos)

Código	Requerimiento	Prioridad	Subcomp.
RF-UEX-02	**Tipos y subtipos de usuario externo** El sistema debe soportar tipos y subtipos parametrizables de usuario externo (postulantes, becarios, deportistas, actores culturales y otros). Las organizaciones —por ejemplo patrocinadores de deportistas— interactúan a través de su representante, que se identifica con su cédula y queda vinculado a la organización mediante su RUC. **Criterio de aceptación:** Se registran usuarios externos de distintos tipos y subtipos, y un representante vinculado a una organización, cada uno con sus atributos y validaciones. **Fuente:** *Reunión (brecha)* · *Reunión 22-sep*	Debe tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-UEX-04	**Perfiles evolutivos por proceso de negocio** El sistema debe soportar que un usuario externo cambie de perfil conforme avanza en un proceso —por ejemplo inscrito, postulante, beneficiario, devengante y cierre en el sistema de becas— conservando el historial. **Criterio de aceptación:** El cambio de etapa modifica los permisos efectivos y el histórico queda consultable. **Fuente:** *Reunión · Reunión 22-sep*	Debe tener	C2.2
RF-UEX-05	**Transición de usuario externo a interno** Cuando un ciudadano pasa a ser docente o funcionario, el sistema debe crear la identidad interna preservando el vínculo con su identidad ciudadana previa y todo su histórico. **Criterio de aceptación:** Dado el caso de un postulante que gana un concurso, el sistema conserva la trazabilidad entre ambas identidades. **Fuente:** *Reunión (brecha) · Entregable 1 · Reunión 22-sep*	Debe tener	C2.2
RF-UEX-06	**Coexistencia de identidad interna y externa** Las identidades interna y externa de una misma persona deben poder coexistir, con credenciales con atributos diferentes y ámbitos de acceso independientes. **Criterio de aceptación:** Un funcionario que postula como ciudadano a un concurso accede a ambos ámbitos sin conflicto ni fusión forzada de cuentas, y ambas quedan vinculadas a su identificación. **Fuente:** *Reunión · TDR C2.2 · Reunión 22-sep*	Debe tener	C2.2
RF-UEX-07	**Autenticación externa sin licenciamiento de Workspace** El Ministerio no asignará licencias de Google Workspace a usuarios externos. La identidad ciudadana debe resolverse sin costo o con un costo informado y justificado por tipo de usuario, evaluando alternativas como Cloud Identity Free (con ampliación de cuota) o la plataforma de identidad de GCP. **Criterio de aceptación:** El diseño de identidad ciudadana está cuantificado en costo por tipo de usuario, no escala el licenciamiento de Workspace con el número de ciudadanos y es aprobado por MINEDEC. **Fuente:** *Derivado · TDR C2.2 · Reunión 22-sep*	Debe tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-UEX-08	**Evaluación de mecanismos de identidad ciudadana** Debe evaluarse y recomendarse el mecanismo de identidad para ciudadanos: cuentas en Cloud Identity Free, plataforma de identidad de GCP o federación con cuentas personales (Gmail u otros), considerando costo, cuota, seguridad, ciclo de vida y autorrecuperación de contraseña. **Criterio de aceptación:** Se documenta la evaluación con criterios de seguridad, costo y experiencia de usuario, y MINEDEC aprueba la alternativa. **Fuente:** *Derivado · Reunión 22-sep*	Debería tener	C2.2

3.5 Administración Delegada y Autoservicio

Código	Requerimiento	Prioridad	Subcomp.
RF-ADM-01	**Consola de administración centralizada** Debe implementarse una consola que permita gestionar aplicaciones federadas y activos tecnológicos, registrarlas y publicarlas (RF-ADM-08), configuraciones de integración, atributos, tipos de usuario, roles, perfiles, permisos, parámetros de federación y usuarios internos y externos. **Criterio de aceptación:** Todas las operaciones administrativas previstas se ejecutan desde la consola, sin acceso directo a base de datos. **Fuente:** *Reunión · TDR C2.2*	Debe tener	C2.2
RF-ADM-02	**Roles de administrador personalizados** Deben poder crearse roles administrativos acotados —por ejemplo crear usuarios o restablecer contraseñas sin poder eliminarlos— aplicando el principio de mínimo privilegio. **Criterio de aceptación:** Se crea un rol administrativo restringido y se verifica que no puede ejecutar las acciones excluidas. **Fuente:** *Entregable 1*	Debe tener	C2.2
RF-ADM-03	**Delegación por unidad organizativa** La administración debe poder delegarse por unidad organizativa o institución, de modo que cada área gestione los usuarios de su propio ámbito, usando las capacidades nativas de Cloud Identity. **Criterio de aceptación:** Un administrador delegado opera únicamente sobre su ámbito asignado. **Fuente:** *Entregable 1 · Reunión*	Debería tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-ADM-04	**Autoservicio del usuario final** El usuario debe poder consultar su perfil, gestionar sus métodos de segundo factor y ver a qué aplicaciones federadas tiene acceso desde el lanzador de aplicaciones. **Criterio de aceptación:** El usuario ejecuta las operaciones de autoservicio previstas sin intervención de la mesa de servicio. **Fuente:** *Derivado*	Debería tener	C2.2
RF-ADM-05	**Operaciones masivas** Deben soportarse la carga y modificación masiva de usuarios y de sus asignaciones de grupos, roles y perfiles, con validación previa y reporte de resultados, considerando el volumen de docentes y estudiantes. **Criterio de aceptación:** Una carga masiva reporta registros procesados, rechazados y el motivo de cada rechazo. **Fuente:** *Derivado*	Debería tener	C2.2
RF-ADM-07	**Procedimientos transitorios de gestión** Mientras se automatiza la gestión, deben documentarse y sostenerse procedimientos manuales o semiautomáticos que aseguren la continuidad operativa. **Criterio de aceptación:** Los procedimientos transitorios están documentados y asignados a responsables. **Fuente:** *Entregable 1*	Debería tener	C2.2
RF-ADM-08	**Publicación de aplicaciones desde la consola** El superadministrador debe poder publicar una aplicación del patrón 2 desde la consola, sin acceso a Google Cloud: la plataforma crea los recursos con Infrastructure Manager, muestra una vista previa antes de aplicar, publica una aplicación a la vez y guía los pasos que no se automatizan (firewall y DNS del MINEDEC, y alta en Google para el patrón 1). Debe permitir modificar, suspender, despublicar y revertir. **Criterio de aceptación:** Una aplicación se publica, se suspende y se revierte desde la consola sin que ninguna persona use roles de Google Cloud, y cada publicación queda registrada con su autor, versión y resultado. **Fuente:** *Documento de Arquitectura de Solución SSO (5.1.4)*	Debe tener	C2.2 · C2.3

3.6 Integración de Aplicaciones

Código	Requerimiento	Prioridad	Subcomp.
RF-INT-01	**Integración de las dos aplicaciones legadas** Deben integrarse dos aplicaciones legadas del Ministerio con el SSO, incluyendo la modificación de frontend y backend, el filtro o librería SP (OIDC como protocolo principal y SAML 2.0 como alternativo, con el módulo de integración de referencia), el almacén de llaves (JKS), el mapeo de atributos y perfiles y el desacople de las contraseñas locales, sin alterar la funcionalidad de las aplicaciones. **Criterio de aceptación:** Las dos aplicaciones autentican contra el IdP central en ambiente productivo, con acta de aceptación funcional y evidencia de pruebas. **Fuente:** *Entregable 1 · Reunión · TDR C2.3*	Debe tener	C2.3
~~RF-INT-02~~	~~**Refactorización de la aplicación SIEE — Retirado en la v0.4: depende de la selección de D-03 y lo cubre RF-INT-03 (Anexo A).**~~ ~~En caso de ser seleccionada como una de las dos aplicaciones legadas, la aplicación SIEE debe integrarse mediante la librería spring-security-saml2-service-provider, por ser la de menor impacto sobre su base tecnológica actual.~~ ~~**Criterio de aceptación:** SIEE autentica vía SAML contra Cloud Identity, con las limitaciones de versión documentadas y resueltas.~~ ~~**Fuente:** *Entregable 2*~~	~~Debe tener~~	~~C2.3~~
RF-INT-03	**Componente de federación SP/RP reutilizable** Debe desarrollarse un componente SP/RP reutilizable (SAML 2.0 y OIDC), ~~con su patrón de integración documentado para aplicaciones legadas Java y aplicaciones nuevas del Proyecto de Transformación Digital~~ como paquete estándar de integración: un módulo de integración de referencia para el stack de cada aplicación de C2.3, perfiles OIDC y SAML, el contrato de Sistema de Autenticación Centralizado SSO en OpenAPI, la custodia de llaves (JKS en memoria), pruebas de conformidad y una guía de integración, reutilizable por aplicaciones de cualquier lenguaje y por las nuevas del Proyecto de Transformación Digital. **Criterio de aceptación:** El equipo de MINEDEC integra una aplicación adicional usando el componente y su documentación, sin acompañamiento del proveedor. **Fuente:** *Entregable 2 · TDR C2.2*	Debe tener	C2.2 · C2.3

Código	Requerimiento	Prioridad	Subcomp.
RF-INT-06	**Referencia técnica y transferencia de conocimiento** El código fuente de las integraciones y el Manual Técnico (guías de API y mantenimiento) deben servir de referencia técnica para que el equipo del Ministerio replique la integración. **Criterio de aceptación:** El equipo de MINEDEC ejecuta la demostración y reproduce una integración a partir de ella. **Fuente:** *Entregable 1 · TDR C2.3*	Debe tener	C2.2 · C2.3
RF-INT-09	**Convivencia durante la transición** Las aplicaciones aún no migradas deben seguir operando con su mecanismo actual mientras dure la migración, sin interrupción del servicio. Cada aplicación del patrón 2 se publica en dos tiempos: piloto, con el acceso anterior abierto, y corte. **Criterio de aceptación:** Ninguna aplicación fuera del alcance pierde disponibilidad durante la implementación. **Fuente:** *Reunión*	Debe tener	C2.3
RF-INT-10	**Integración perimetral de aplicaciones (patrón 2)** Las aplicaciones que no se modifiquen deben poder protegerse con un punto de ejecución de políticas (PEP) que autentica al usuario con Google y consulta a Sistema de Autenticación Centralizado SSO en cada petición, en dos niveles: protegida (la aplicación no cambia) o integrada (la aplicación retira su login y lee las cabeceras de identidad X-Minedec-*). **Criterio de aceptación:** Una aplicación protegida solo es accesible a través del PEP con la autorización de Sistema de Autenticación Centralizado SSO, y una integrada recibe la identificación, los roles y el ámbito del usuario en las cabeceras del contrato. **Fuente:** *Documento de Arquitectura de Solución SSO (5.1.2 y 5.1.5)*	Debería tener	C2.3

3.7 Auditoría, Trazabilidad y Control

Código	Requerimiento	Prioridad	Subcomp.
RF-AUD-01	**Registro de eventos de autenticación** Debe registrarse todo intento de autenticación —exitoso o fallido— con usuario, fecha y hora, origen, aplicación destino y método de segundo factor empleado. **Criterio de aceptación:** La consulta de eventos permite reconstruir la actividad de autenticación de cualquier usuario en un período dado. **Fuente:** *Reunión · Entregable 1*	Debe tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-AUD-02	**Registro de eventos de autorización** Debe registrarse toda concesión, modificación y revocación de roles y perfiles, indicando quién la otorgó, sobre quién recae, qué rol o perfil, y sus fechas de inicio y baja. **Criterio de aceptación:** Ante un requerimiento de control, se demuestra quién otorgó cualquier rol vigente o histórico y durante qué período estuvo activo. **Fuente:** *Reunión · Reunión 22-sep*	Debe tener	C2.2
RF-AUD-03	**Registro de eventos administrativos** Toda operación administrativa sobre identidades, aplicaciones, roles y políticas debe quedar registrada con su autor. **Criterio de aceptación:** Ninguna operación administrativa queda sin autoría registrada. **Fuente:** *Derivado*	Debe tener	C2.2
RF-AUD-04	**Trazabilidad histórica de la identidad** Debe poder reconstruirse la historia completa de una persona en el ecosistema: identidades, cuentas, dominios, roles y accesos, con sus fechas de vigencia. **Criterio de aceptación:** Dada una identificación, el sistema presenta la línea de tiempo completa de esa persona. **Fuente:** *Reunión (brecha) · Reunión 22-sep*	Debe tener	C2.2
RF-AUD-05	**Retención de la evidencia** Los registros de auditoría deben conservarse durante el período que establezca la normativa aplicable y la política interna del Ministerio. **Criterio de aceptación:** La política de retención está configurada y documentada; se verifica la disponibilidad de registros al límite del período. **Fuente:** *Derivado*	Debe tener	C2.2
RF-AUD-06	**Integridad de la pista de auditoría** Los registros de auditoría deben ser inalterables por los usuarios y administradores del sistema. **Criterio de aceptación:** Ningún perfil, incluido el de mayor privilegio funcional, puede modificar o borrar registros de auditoría. **Fuente:** *Derivado*	Debe tener	C2.2

Código	Requerimiento	Prioridad	Subcomp.
RF-AUD-07	**Reportes de accesos y administración** Deben generarse reportes de accesos exitosos y fallidos, quién tiene acceso a qué aplicativo y con qué perfil, altas, bajas y suspensiones del período, cuentas inactivas y administradores privilegiados vigentes. **Criterio de aceptación:** Los reportes se generan bajo demanda y en formato exportable, sin desarrollo adicional. **Fuente:** *Reunión · TDR C2.2*	Debe tener	C2.2
RF-AUD-08	**Monitoreo centralizado de la actividad** La observabilidad de la actividad de usuarios debe apoyarse en las herramientas del Centro de seguridad de Google Workspace y de Google Cloud Platform. **Criterio de aceptación:** Los tableros de monitoreo están operativos y accesibles al equipo de seguridad del Ministerio. **Fuente:** *Entregable 1*	Debe tener	C2.2
RF-AUD-09	**Alertamiento ante eventos de riesgo** Deben configurarse alertas sobre eventos críticos: elevación de privilegios, accesos anómalos, fallos de aprovisionamiento y desactivación de políticas de seguridad. **Criterio de aceptación:** Se dispara una alerta de prueba por cada tipo de evento crítico definido. **Fuente:** *Derivado · TDR C2.2*	Debería tener	C2.2

4. Requerimientos no funcionales

Se definen ~~39~~ 42 requerimientos no funcionales. Su verificación debe formar parte de los criterios de aceptación del paso a producción.

4.1 Seguridad

Código	Requerimiento	Prioridad
RNF-SEG-01	**Cifrado en tránsito** Toda comunicación entre componentes, aplicaciones y servicios externos debe usar TLS 1.2 o superior, con preferencia por TLS 1.3. **Verificación:** Escaneo de configuración sin protocolos ni cifradores obsoletos habilitados. **Fuente:** *Entregable 2*	Debe tener
RNF-SEG-02	**Cifrado en reposo** Los datos de identidad, configuración de federación y auditoría deben almacenarse cifrados en reposo. **Verificación:** Verificación de configuración de cifrado en los almacenes de datos utilizados. **Fuente:** *Derivado*	Debe tener
RNF-SEG-04	**Gestión y rotación de secretos y certificados** Las credenciales de servicio y los certificados de firma SAML deben custodiarse en un gestor de secretos y contar con procedimiento y calendario de rotación. Las credenciales de las aplicaciones ante Sistema de Autenticación Centralizado SSO se entregan una sola vez y se guardan solo como hash. **Verificación:** Existe inventario de certificados con fecha de expiración y procedimiento de rotación probado. **Fuente:** *Derivado*	Debe tener
RNF-SEG-05	**Mínimo privilegio** Toda cuenta de servicio, rol administrativo e integración debe operar con el conjunto mínimo de permisos necesario. La publicación de aplicaciones usa roles personalizados con permisos exactos, y ninguna persona necesita roles de Google Cloud para publicar. **Verificación:** Revisión de permisos sin cuentas con privilegios superiores a los requeridos por su función. **Fuente:** *Entregable 1*	Debe tener
RNF-SEG-07	**Pruebas de seguridad previas a producción** Antes del paso a producción deben ejecutarse pruebas de vulnerabilidades y de seguridad de la solución, con remediación de los hallazgos críticos y altos. **Verificación:** Informe de pruebas con hallazgos críticos y altos cerrados o con plan de remediación aceptado. **Fuente:** *Reunión*	Debe tener

Código	Requerimiento	Prioridad
RNF-SEG-08	**Resistencia a suplantación** La solución debe mitigar fuerza bruta, robo de sesión, phishing y toma de cuenta, priorizando métodos de segundo factor resistentes a phishing para perfiles privilegiados. **Verificación:** Los perfiles administrativos usan llaves de seguridad o método equivalente resistente a phishing. **Fuente:** *Entregable 2 · Derivado*	Debe tener
RNF-SEG-09	**Cierre de red de las aplicaciones perimetrales** Las aplicaciones del patrón 2 solo deben aceptar tráfico del PEP (subred proxy-only del balanceador interno), y debe cerrarse el acceso directo de los usuarios, incluido el de la red interna del MINEDEC. **Verificación:** Un intento de acceso directo a la aplicación desde la red de usuarios es rechazado por el firewall. **Fuente:** *Documento de Arquitectura de Solución SSO (5.1.3)*	Debe tener
RNF-SEG-10	**Denegación ante falla de la autorización (fail-close)** Si Sistema de Autenticación Centralizado SSO no responde o devuelve un error, el PEP y las aplicaciones del patrón 1 deben negar el acceso. **Verificación:** Con Sistema de Autenticación Centralizado SSO fuera de servicio en pruebas, ninguna petición protegida es autorizada. **Fuente:** *Documento de Arquitectura de Solución SSO (5.1.5)*	Debe tener

4.2 Rendimiento y escalabilidad

Código	Requerimiento	Prioridad
RNF-REN-01	**Volumetría objetivo** La solución debe dimensionarse para aproximadamente 10.000 usuarios administrativos, 160.000 docentes y 2,1 millones de estudiantes, más la población de usuarios externos (por ejemplo, unos 76.000 aspirantes en la última convocatoria de becas), y para la incorporación progresiva de alrededor de 170 aplicativos. **Verificación:** El dimensionamiento está documentado y validado con pruebas de carga proporcionales. **Fuente:** *Reunión · TDR C1 · Reunión 22-sep*	Debe tener
RNF-REN-02	**Tiempo de autenticación** El flujo completo de autenticación federada debe procesarse de manera ágil y con tiempos de respuesta mínimos del lado del servidor, excluyendo la latencia de red del usuario. **Verificación:** Pruebas de rendimiento con el objetivo cumplido bajo carga nominal. **Fuente:** *Derivado*	Debería tener

Código	Requerimiento	Prioridad
RNF-REN-03	**Tiempo de respuesta de autorización** La consulta de roles y permisos efectivos debe ejecutarse con una latencia mínima, garantizando una resolución de autorización casi en tiempo real. **Verificación:** Pruebas de rendimiento con el objetivo cumplido bajo carga nominal. **Fuente:** *Derivado*	Debería tener
RNF-REN-04	**Concurrencia en períodos pico** La solución debe sostener los picos de concurrencia propios de matrículas, postulaciones a becas y procesos de méritos y oposición, cuya magnitud debe ser definida por MINEDEC. **Verificación:** Prueba de carga superada al nivel de concurrencia pico acordado. **Fuente:** *Reunión · Derivado*	Debe tener
RNF-REN-05	**Escalabilidad horizontal** Los componentes desarrollados (Sistema de Autenticación Centralizado SSO, su consola de administración y el PEP; el módulo de integración corre dentro de cada aplicación) deben escalar horizontalmente de forma elástica ante el incremento de carga. **Verificación:** El componente escala automáticamente en prueba de carga sin degradación del servicio. **Fuente:** *Entregable 2*	Debe tener
RNF-REN-06	**Oportunidad del aprovisionamiento** La frecuencia de aprovisionamiento desde las fuentes autoritativas (APIs de matrícula y bases de datos de usuarios) debe definirse de modo que no degrade la operación y satisfaga la oportunidad exigida para altas y bajas. La sincronización de Sistema de Autenticación Centralizado SSO con Cloud Identity es de solo lectura, se ajusta a las cuotas de la Directory API y queda fuera del camino crítico de la autenticación. **Verificación:** El aprovisionamiento cumple la ventana acordada sin impacto perceptible en producción. **Fuente:** *Entregable 2 · Reunión*	Debe tener

4.3 Disponibilidad y continuidad

Código	Requerimiento	Prioridad
RNF-DIS-01	**Nivel de servicio** Al convertirse en punto único de acceso, la solución debe cumplir el nivel de disponibilidad que MINEDEC defina formalmente; se propone como base 99,5 % mensual en horario de servicio. **Verificación:** El acuerdo de nivel de servicio está formalizado y medido. **Fuente:** *Derivado*	Debe tener

Código	Requerimiento	Prioridad
RNF-DIS-02	**Ausencia de punto único de fallo** Los componentes de aprovisionamiento y el sistema de permisos deben contar con esquema de redundancia o de recuperación documentado. **Verificación:** La caída de un componente de aprovisionamiento no interrumpe la autenticación y se recupera dentro del RTO. **Fuente:** *Derivado*	Debería tener
RNF-DIS-03	**Acceso de emergencia** Deben existir cuentas de emergencia (break-glass) excluidas de la federación, custodiadas y auditadas, para recuperar la administración ante una indisponibilidad del IdP. **Verificación:** Las cuentas de emergencia están definidas, custodiadas y su uso genera alerta inmediata. **Fuente:** *Derivado*	Debe tener
RNF-DIS-04	**Objetivos de recuperación** Deben definirse y probarse RTO y RPO para los componentes de identidad y autenticación, incluidos los protocolos de recuperación exigidos por el TDR. **Verificación:** Ejercicio de recuperación ejecutado dentro de los objetivos definidos. **Fuente:** *Derivado · TDR C2.2*	Debe tener
RNF-DIS-05	**Conectividad híbrida redundante** La conexión con las redes donde están las aplicaciones debe usar una topología de 99,99 % (HA VPN o Cloud Interconnect), independiente por ambiente. **Verificación:** La conexión de producción sigue operativa ante la caída de un túnel o enlace. **Fuente:** *Documento de Arquitectura de Solución SSO (5.1.3)*	Debería tener

4.4 Interoperabilidad y estándares

Código	Requerimiento	Prioridad
RNF-INT-01	**Estándares abiertos** La solución debe basarse en SAML 2.0, OpenID Connect y OAuth 2.0 (incluido client credentials para autenticar a las aplicaciones ante Sistema de Autenticación Centralizado SSO), y evaluar SCIM para el aprovisionamiento entre sistemas. **Verificación:** Las integraciones se realizan exclusivamente sobre estándares abiertos. **Fuente:** *Entregable 2*	Debe tener
RNF-INT-02	**APIs documentadas** Las interfaces expuestas deben estar documentadas bajo especificación abierta (OpenAPI) y versionadas. **Verificación:** La documentación de API está publicada y permite integrar sin acompañamiento. **Fuente:** *Derivado*	Debe tener

Código	Requerimiento	Prioridad
RNF-INT-03	**Independencia de proveedor** El diseño debe evitar acoplamientos que impidan sustituir el proveedor de identidad en el futuro sin reescribir las aplicaciones. **Verificación:** Las aplicaciones dependen del estándar y no de extensiones propietarias del proveedor. **Fuente:** *Entregable 2*	Debería tener
RNF-INT-04	**Compatibilidad con el parque legado** La solución debe operar sobre las versiones tecnológicas existentes del parque legado, incluidas aplicaciones Java sobre servidores de aplicaciones antiguos y versiones no actuales de Spring. **Verificación:** La integración de la aplicación legada funciona sin exigir actualización mayor de su plataforma base. **Fuente:** *Entregable 2*	Debe tener

4.5 Usabilidad y accesibilidad

Código	Requerimiento	Prioridad
RNF-USA-01	**Idioma** Todas las interfaces de usuario y administración, así como los mensajes del sistema, deben estar en español. **Verificación:** Revisión de interfaz sin textos en otro idioma. **Fuente:** *Derivado*	Debe tener
RNF-USA-02	**Accesibilidad** Las interfaces de cara al ciudadano y al usuario final deben cumplir los criterios de accesibilidad WCAG 2.1 nivel AA. **Verificación:** Auditoría de accesibilidad con los criterios de nivel AA satisfechos. **Fuente:** *Derivado*	Debería tener
RNF-USA-03	**Experiencia unificada** Debe eliminarse la confusión derivada de múltiples cuentas y métodos de autenticación, especialmente para docentes y estudiantes. **Verificación:** Cada tipo de usuario cuenta con un único método de acceso documentado y comunicado. **Fuente:** *Entregable 1*	Debe tener
RNF-USA-04	**Acceso desde dispositivos móviles** Las interfaces de autenticación y autoservicio deben ser utilizables desde dispositivos móviles. **Verificación:** Pruebas de uso satisfactorias en navegadores móviles de uso corriente. **Fuente:** *Derivado*	Debería tener

Código	Requerimiento	Prioridad
RNF-USA-05	**Mensajes comprensibles** Los mensajes de error y de estado deben ser comprensibles para usuarios no técnicos y orientar la acción correctiva. **Verificación:** Revisión de los mensajes por el equipo funcional de MINEDEC. **Fuente:** *Derivado*	Debería tener

4.6 Operación y observabilidad

Código	Requerimiento	Prioridad
RNF-OPE-01	**Observabilidad** Deben centralizarse métricas, registros y trazas de los componentes de identidad, autenticación y federación. **Verificación:** Los tableros presentan la salud de todos los componentes de la solución. **Fuente:** *Entregable 1 · Derivado*	Debe tener
RNF-OPE-02	**Alertas operativas** Los fallos de aprovisionamiento, de emisión de aserciones y de consulta al sistema de permisos deben generar alerta a los responsables. **Verificación:** Cada tipo de fallo dispara alerta verificada en prueba. **Fuente:** *Derivado*	Debe tener
RNF-OPE-03	**Documentación de operación** Deben entregarse manuales de instalación, configuración, operación y procedimientos de contingencia. **Verificación:** La documentación permite a un tercero operar la solución sin acompañamiento. **Fuente:** *Derivado*	Debe tener
RNF-OPE-04	**Separación de ambientes** Deben existir ambientes diferenciados de desarrollo, pruebas y producción, con datos de prueba que no expongan información personal real. **Verificación:** Los tres ambientes están operativos y aislados entre sí. **Fuente:** *Reunión*	Debe tener
RNF-OPE-05	**Casos de prueba y evidencia formal** Debe entregarse un juego formal de casos de prueba funcionales y de integración, con evidencia de ejecución aprobada por MINEDEC, subsanando la ausencia de casos de prueba de la fase anterior. **Verificación:** MINEDEC aprueba formalmente la evidencia de ejecución de los casos de prueba. **Fuente:** *Reunión (brecha)*	Debe tener

Código	Requerimiento	Prioridad
RNF-OPE-06	**Transferencia de conocimiento** Debe ejecutarse un plan de capacitación técnica y funcional y de transferencia de conocimiento al personal designado por el Ministerio. **Verificación:** El plan se ejecuta y el equipo de MINEDEC replica de forma autónoma una integración. **Fuente:** *Entregable 1 · TDR C2.2*	Debe tener

4.7 Mantenibilidad y evolución

Código	Requerimiento	Prioridad
RNF-MAN-01	**Parametrización sin desarrollo** Las políticas, catálogos de atributos, roles y perfiles y los parámetros de federación deben ser parametrizables por configuración, sin requerir recompilación ni despliegue. **Verificación:** Un cambio de parámetro surte efecto sin nuevo despliegue. **Fuente:** *Reunión*	Debería tener
RNF-MAN-02	**Entrega de código y artefactos** El código fuente, los artefactos de despliegue y la documentación técnica deben entregarse a MINEDEC, que conserva la propiedad de la solución. **Verificación:** Los repositorios y artefactos están en poder del Ministerio al cierre de cada fase. **Fuente:** *Derivado*	Debe tener
RNF-MAN-03	**Versionamiento y despliegue continuo** La solución debe gestionarse con control de versiones, canalizaciones de integración y despliegue continuo (CI/CD) e infraestructura como código (Terraform) desplegada con Infrastructure Manager. **Verificación:** Los despliegues se ejecutan desde la canalización y son reproducibles. **Fuente:** *Derivado · TDR C2.2 · TDR C2.3*	Debe tener
RNF-MAN-04	**Arquitectura evolutiva** La arquitectura debe permitir incorporar nuevas aplicaciones, tipos de usuario y métodos de autenticación sin rediseño estructural, y no debe impedir la futura asignación automática de roles y perfiles desde el módulo de movimiento de personal de Talento Humano. **Verificación:** La incorporación de una aplicación nueva no exige modificar el modelo de datos ni el núcleo de la solución. **Fuente:** *Entregable 1 · Entregable 2 · Reunión 22-sep*	Debe tener

4.8 Cumplimiento normativo

Código	Requerimiento	Prioridad
RNF-CUM-01	**Protección de datos personales** El tratamiento de datos debe ajustarse a la Ley Orgánica de Protección de Datos Personales del Ecuador, aplicando minimización, finalidad determinada, base de licitud y derechos del titular. **Verificación:** Existe registro de actividades de tratamiento y evaluación de impacto para los tratamientos de alto riesgo. **Fuente:** *Derivado*	Debe tener
RNF-CUM-02	**Esquema Gubernamental de Seguridad de la Información** La solución debe alinearse con el EGSI vigente para entidades de la Administración Pública Central. **Verificación:** Se documenta la matriz de controles del EGSI aplicables y su cumplimiento. **Fuente:** *Derivado*	Debe tener
RNF-CUM-03	**Datos de niñas, niños y adolescentes** El tratamiento de datos de la población estudiantil menor de edad debe contar con salvaguardas reforzadas y consentimiento del representante legal cuando corresponda. **Verificación:** Los flujos que involucran menores incorporan la intervención del representante legal. **Fuente:** *Reunión · Derivado*	Debe tener
RNF-CUM-04	**Localización y soberanía del dato** Debe definirse con MINEDEC la política de residencia de los datos de identidad y su compatibilidad con la normativa aplicable. **Verificación:** La política de residencia está definida, aprobada y configurada en la plataforma. **Fuente:** *Derivado*	Debe tener

5. Brechas identificadas y decisiones

5.1 Brechas

Brechas vigentes tras la reunión del 22 de septiembre, con sus códigos originales. Las brechas BR-05, BR-06 y BR-09 se consideran resueltas (ver 5.3). Deben cerrarse durante la fase de análisis funcional, antes del diseño detallado.

Código	Brecha	Criticidad	Requerimientos asociados
BR-01	**Modelo de identidad ciudadana no definido** El Ministerio no asignará licencias de Workspace a externos, necesita resolver el ciclo de vida y la autorrecuperación de contraseñas de millones de ciudadanos y no puede restringirlos a cuentas Gmail. Las alternativas discutidas (Cloud Identity Free con cuota ampliada, plataforma de identidad de GCP o federación con cuentas personales) no están evaluadas. **Acción propuesta:** Evaluar las alternativas con costo, cuota y experiencia de usuario, y presentar una recomendación a MINEDEC.	Alto	RF-AUT-11 · RF-UEX-07 · RF-UEX-08
BR-02	**Vinculación de cuentas de una misma persona** El caso del funcionario que postula como ciudadano con su correo personal y del ciudadano que ingresa al Ministerio exige vincular varias cuentas a una única cédula. El mecanismo quedó por definir según la mejor práctica. La arquitectura ya define la identidad maestra por cédula en Sistema de Autenticación Centralizado SSO, con varias cuentas por persona; falta el mecanismo de la cuenta ciudadana (D-02, D-13). **Acción propuesta:** Diseñar el modelo de identidad maestra por cédula y el procedimiento de vinculación de cuentas.	Alto	RF-GI-09 · RF-GI-10 · RF-UEX-05 · RF-UEX-06
BR-07	**Ausencia de casos de prueba de la fase anterior** Solo se probó el conector entre cédula y cuenta de Google; el módulo autorizador nunca se probó y no existen casos de uso formales. **Acción propuesta:** Considerar lo existente como no verificado y planificar pruebas completas desde cero.	Medio	RNF-OPE-05
BR-08	**Secuencia invertida respecto del informe de necesidad** El informe de necesidad establece implementar primero el SSO (C2.2) y luego conectar dos aplicaciones (C2.3). La fase anterior ejecutó el orden inverso. **Acción propuesta:** Retomar la secuencia C2.2 → C2.3 y tratar el conector existente como solución transitoria.	Medio	RF-INT-01

Código	Brecha	Criticidad	Requerimientos asociados
BR-10	**Licenciamiento y costos no cuantificados** El TDR no incluye licenciamiento de Cloud Identity. Cloud Identity Free tiene una cuota máxima (se mencionaron 50.000 identidades) que no cubre la población externa, y una entidad pública difícilmente puede justificar costos por ciudadanos que aún no tienen relación con el Ministerio. A esto se suma el costo de la alternativa de PEP (D-16). **Acción propuesta:** Cuantificar el costo por tipo de usuario, gestionar con Google una ampliación de cuota e informar a MINEDEC cualquier costo antes de incurrirlo.	Alto	RF-UEX-07 · RNF-REN-01
BR-11	**Inventario de aplicativos, tipos de usuario y roles pendiente** MINEDEC solicitará por memorando a todas las áreas el detalle de aplicativos, tipos de usuario, roles, perfiles y atributos mínimos. El levantamiento existente de 70 a 80 tipos está incompleto, y la información de Deporte y Cultura será la más difícil de obtener. **Acción propuesta:** Acordar la fecha de entrega del memorando y trabajar con las unidades de negocio que gobernarán cada tipo de usuario.	Alto	RF-AUZ-16 · RF-UEX-02
BR-12	**Aplicaciones legadas no formalizadas** C2.3 compromete la integración de dos aplicaciones legadas, pero su selección no está formalizada ~~más allá de la mención de SIEE y del sistema de becas~~. **Acción propuesta:** Formalizar la selección con criterios de criticidad, viabilidad técnica y valor demostrativo.	Medio	~~RF-INT-01 · RF-INT-02~~ RF-INT-01
BR-13	**Alcance del sistema de permisos frente al plazo** La reunión confirmó que MINEDEC espera un sistema centralizado de permisos completo, mientras el TDR lo enuncia de forma general (administración centralizada de accesos, gestión de roles y perfiles) dentro de un plazo de 70 días. **Acción propuesta:** Acordar con el Administrador del contrato el alcance mínimo de la primera entrega y registrar los cambios de fondo mediante control de cambios.	Alto	RF-AUZ-01 a RF-AUZ-16
BR-14	**Niveles de servicio y volumetría sin definir** No existen valores acordados de disponibilidad, RTO, RPO ni concurrencia pico, indispensables para las pruebas de carga y estrés que exige el TDR. **Acción propuesta:** Acordar los niveles de servicio con MINEDEC antes del diseño detallado.	Medio	RNF-DIS-01 · RNF-DIS-04 · RNF-REN-04

Código	Brecha	Criticidad	Requerimientos asociados
BR-15	**Oportunidad de altas y bajas** La necesidad es de actualización oportuna, pero las fuentes autoritativas (matrícula, bases de datos de usuarios) y su frecuencia de aprovisionamiento no están definidas para todos los tipos de usuario. **Acción propuesta:** Acordar el SLA de propagación y la fuente autoritativa de cada tipo de usuario. La arquitectura ya define las fuentes (C1.4 para estudiantes y los administradores del MINEDEC para docentes y administrativos), la sincronización casi en tiempo real y la revocación en 300 segundos o menos; falta el SLA formal (D-07).	Alto	RF-GI-05 · RF-GI-06 · RNF-REN-06
BR-16	**Aplicabilidad del cierre de sesión único** El TDR condiciona el SLO a un análisis de aplicabilidad con el Administrador del contrato, mientras que la línea base lo clasifica como «Debe tener». Además, Google Cloud Identity no implementa el SLO, por lo que el cierre coordinado se resuelve con revalidación contra Sistema de Autenticación Centralizado SSO. **Acción propuesta:** Definir con el Administrador las aplicaciones en las que aplica el SLO.	Medio	RF-AUT-06
BR-17	**Plazo de acompañamiento post-producción** El TDR definitivo indica setenta (70) en configuración y noventa (90) días posterior, para la fase de soporte en las condiciones generales). **Acción propuesta:** Asumir 90 días, por ser el mínimo general, y confirmarlo con el Administrador del contrato.	Bajo	RNF-OPE-03 · RNF-OPE-06
BR-18	**Personas sin cédula** Existen estudiantes sin cédula a los que MINEDEC asigna un código propio, válido solo en el Ministerio y actualizable a cédula. Ese código no aplica en Deporte y Cultura, donde pueden existir deportistas menores sin documento. **Acción propuesta:** Definir el tratamiento del identificador alternativo por viceministerio. El código MINEDEC ya está previsto como tipo de identificación (CODIGO_MINEDEC); falta su tratamiento en Deporte y Cultura.	Medio	RF-GI-12 · RF-GI-15
BR-19	**Ubicación de las aplicaciones y conectividad híbrida no definidas** No se conoce dónde están las aplicaciones (datacenter, sedes, entes externos u otras nubes), ni el equipo de borde ni el operador de enlaces, y de ello depende la conexión con Google Cloud. **Acción propuesta:** Levantar el inventario de ubicaciones y elegir la opción de conectividad según la necesidad real (D-17).	Alto	RF-INT-01 · RF-INT-10 · RNF-DIS-05

Código	Brecha	Criticidad	Requerimientos asociados
BR-20	**Dominios, tenants y accesos para la sincronización no definidos** No se conocen los dominios definitivos de docentes y administrativos ni si comparten tenant, y no está definido quién habilita la delegación de dominio de solo lectura y el sink de auditoría en la organización de GCP. **Acción propuesta:** Definir dominios y tenants (D-21) y los accesos de lectura (D-20) antes de configurar la federación y la sincronización.	Alto	RF-GI-01 · RF-GI-05 · RNF-REN-06

5.2 Decisiones pendientes del Ministerio

Código	Decisión	Responsable	Impacto	¿Bloquea el desarrollo?
D-02	Mecanismo de identidad y credenciales para ciudadanos, y su costo	MINEDEC – Coordinación General de TIC	Condiciona la autenticación ciudadana, el licenciamiento y la autorrecuperación	Solo el flujo de usuarios externos
D-03	Selección formal de las dos aplicaciones legadas	MINEDEC – Desarrollo de Proyectos de TI	Determina el esfuerzo de integración de C2.3	Sí: todo C2.3 (el módulo de integración depende del stack)
~~D-04~~	~~Plataforma del sistema de permisos: desarrollo a medida, producto de mercado (p. ej. Keycloak) o reutilización del módulo del proveedor anterior~~ — Resuelta en la v0.4 (ver 5.3).	~~Comité conjunto MINEDEC – contratista~~	~~Define el esfuerzo, el costo y el plazo de construcción~~	—
~~D-05~~	~~Estructura organizacional del Ministerio fusionado que reemplaza a «sede»~~ — Resuelta en la v0.4 (ver 5.3).	~~MINEDEC – áreas de negocio~~	~~Es prerrequisito de las OUs, grupos y dimensiones del modelo de permisos~~	—
D-06	Niveles de servicio: disponibilidad, RTO, RPO y concurrencia pico	MINEDEC – Coordinación General de TIC	Determina la alta disponibilidad y los escenarios de prueba de carga	No el inicio; sí el dimensionamiento y las pruebas de carga
D-07	SLA de propagación de altas y bajas y fuente autoritativa por tipo de usuario	MINEDEC – Talento Humano y TIC	Define los procesos de aprovisionamiento	No

Código	Decisión	Responsable	Impacto	¿Bloquea el desarrollo?
D-10	Política de residencia y tratamiento de datos personales, con foco en menores de edad	MINEDEC – asesoría jurídica	Condiciona la configuración de la plataforma y el cumplimiento normativo	La región de GCP de los proyectos, antes de crearlos
D-11	Aplicaciones en las que aplica el cierre de sesión único (SLO) (Google no implementa SLO: se decide en qué aplicaciones se aplica el cierre coordinado por revalidación)	Administrador del contrato	Define el alcance de RF-AUT-06	No
D-12	Entrega del inventario de aplicativos, tipos de usuario, roles, perfiles y atributos mínimos	MINEDEC – Administrador (memorando a las áreas)	Es insumo del catálogo de tipos de usuario y del modelo de permisos	No el inicio; sí el catálogo de tipos de usuario
D-13	Mecanismo de vinculación entre la cuenta institucional y la cuenta ciudadana de una misma persona	MINEDEC – Coordinación General de TIC	Define la identidad maestra por cédula	No (depende de D-02)
D-14	Tratamiento de organizaciones (representante con cédula vinculado al RUC)	MINEDEC – Viceministerio de Deporte	Confirma el alcance de RF-UEX-02	No
D-15	Creación de cuentas de prueba en Cloud Identity para el desarrollo: al menos una por tipo de usuario (administrativo, docente, estudiante y, si aplica, externo), en una unidad organizativa de pruebas aislada, sin datos personales reales y con los permisos de administración delegada que requiera el equipo de desarrollo.	MINEDEC – Administrador	Sin estas cuentas no se pueden configurar ni probar la federación SAML/OIDC, el MFA ni la integración de las aplicaciones legadas. Condiciona el inicio de la construcción y las pruebas de C2.2 y C2.3.	Sí, urgente: las pruebas de inicio de sesión, MFA y sincronización
D-16	Aprobación de la alternativa de PEP para el patrón 2 (Apigee X o GKE Gateway con Envoy) y de su costo	MINEDEC – Coordinación General de TIC	Define la plataforma y el costo de la integración perimetral	Sí: la construcción del patrón 2

Código	Decisión	Responsable	Impacto	¿Bloquea el desarrollo?
D-17	Ubicación de las aplicaciones y opción de conectividad híbrida (HA VPN o Cloud Interconnect): equipo de borde y operador de enlaces	MINEDEC – Infraestructura	Define el enlace con las redes del MINEDEC	Sí: el acceso a las aplicaciones on-prem (C2.3 y patrón 2)
D-18	Subdominio apps.<dominio> para publicar las aplicaciones y su delegación a Cloud DNS	MINEDEC – Infraestructura	Define los nombres y certificados de las aplicaciones publicadas	No el inicio; sí la publicación de aplicaciones
D-19	Responsables de los pasos externos de la publicación: firewall on-prem, DNS institucional y consola de administración de Workspace	MINEDEC – Coordinación General de TIC	Define quién ejecuta los pasos guiados por la consola	No el inicio; sí los pasos externos de cada publicación
D-20	Accesos de lectura para la sincronización: quién autoriza la delegación de dominio, crea la cuenta de administrador de solo lectura y crea el sink de auditoría en la organización de GCP (o concede el permiso)	MINEDEC – Administrador	Habilita la copia de identidad de solo lectura en Sistema de Autenticación Centralizado SSO	Sí, urgente: la sincronización con datos reales y la carga inicial
D-21	Dominios y tenants de Google Workspace / Cloud Identity: dominios de docentes y administrativos, papel de minedec.gob.ec, uno o varios tenants y organizaciones de GCP, y edición de cada uno	MINEDEC – Coordinación General de TIC y Administrador	Condiciona la federación OIDC/SAML, el proyecto de GCP y la sincronización	Sí, urgente: la configuración del SSO, las cuentas de prueba, el proyecto de GCP y la sincronización

5.3 Definiciones resueltas en la reunión del 22 de septiembre

Tema	Definición	Resuelve
Active Directory	Se descarta la sincronización con AD (GCDS y GPS). Cloud Identity es la única fuente de verdad del SSO.	D-01 · BR-09
Dispositivos	La gestión de equipos queda fuera de la iniciativa; el inicio de sesión Windows contra AD no cambia.	—

Tema	Definición	Resuelve
Datos de autorización	Roles, perfiles y permisos residen en una base independiente; Cloud Identity aporta la identidad y la identificación.	BR-06
Identificador único	El usuario es la cédula, no el correo. Una persona puede tener varias cuentas asociadas a una única cédula.	—
Licencias	El Ministerio nunca asignará licencias de Google Workspace a usuarios externos; cualquier costo debe informarse y justificarse.	—
Administración	Administrador es superadministradora y crea los administradores de cada aplicativo.	—
Modelo de permisos	Debe ser flexible y parametrizable, sin replicar el esquema de usuario, sede, aplicación y rol.	BR-05
Plataforma de permisos	Desarrollo a medida: Sistema de Autenticación Centralizado SSO.	D-04
Estructura organizacional	No se modela «sede» ni una estructura que la reemplace: el ámbito se resuelve con atributos (institución, zona, distrito, cartera y tipo de usuario).	D-05

5.4 Definiciones de la arquitectura de solución

Las siguientes definiciones provienen del Documento de Arquitectura de Solución SSO y sustentan los cambios de esta versión (Anexo B).

Tema	Definición	Requerimientos
Patrones de integración	Patrón 1 nativo (aplicaciones de C2.3 y nuevas: OIDC o SAML con Google y consulta a /api/v1/authorize); patrón 2 perimetral con PEP, en nivel protegida o integrada.	RF-INT-01 · RF-INT-03 · RF-INT-10
Protocolos	OIDC como principal (Authorization Code + PKCE S256, único flujo permitido) y SAML 2.0 como alternativo.	RF-AUT-02 · RF-AUT-04 · RF-AUT-05
Identidad	El correo inicia sesión; la cédula (o el código MINEDEC o el pasaporte) identifica a la persona, y Sistema de Autenticación Centralizado SSO la devuelve a las aplicaciones.	RF-GI-11 · RF-GI-12
Relación con Workspace	Sistema de Autenticación Centralizado SSO es de solo lectura: las altas las hacen C1.4 y los administradores del MINEDEC, y un sincronizador copia la identidad a AlloyDB.	RF-GI-05 · RNF-REN-06
Autorización	Siempre en Sistema de Autenticación Centralizado SSO (/api/v1/authorize); los roles y grupos no viajan en la aserción.	RF-AUZ-04 · RF-AUZ-12 · RF-AUZ-13
Cierre de sesión	Google no implementa SLO; se resuelve con cierre local y revalidación contra Sistema de Autenticación Centralizado SSO (300 segundos).	RF-AUT-06
Publicación	Desde la consola con Infrastructure Manager, sin acceso a Google Cloud; los pasos externos se guían y se verifican.	RF-AUZ-03 · RF-ADM-08
Alternativas de PEP	Alternativa 1 Apigee X (recomendada) y Alternativa 2 GKE Gateway con Envoy. La alternativa basada solo en IAP se descartó porque IAP no puede consultar a Sistema de Autenticación Centralizado SSO.	RF-INT-10 · D-16
Nombre	El sistema centralizado de permisos se denomina Sistema de Autenticación Centralizado SSO.	—

6. Resumen de la línea base

Concepto	Cantidad	De ellos, «Debe tener»
Requerimientos funcionales	~~61~~ 63	~~51~~ 52
Requerimientos no funcionales	~~39~~ 42	~~31~~ 33
Ajustados en esta versión	~~23~~ 25	—
Reincorporados en esta versión	~~15~~ 0	—
Nuevos en esta versión	~~2~~ 6	—
Requerimientos fuera de la línea base (Anexo A)	~~32~~ 33	—
Brechas vigentes	~~13~~ 15	—
Decisiones pendientes	~~11~~ 15	—

Distribución de los requerimientos funcionales por subcomponente: ~~53 en C2.2, 3 en C2.3 y 5 compartidos entre ambos~~ 54 en C2.2, 2 en C2.3 y 7 compartidos entre ambos.

6.1 Próximos pasos

- Urgente, para no detener el desarrollo: definición de dominios y tenants de Google (D-21), entrega de las cuentas de prueba (D-15) y accesos de lectura para la sincronización (D-20).
- Antes de aprovisionar la infraestructura: región de GCP según la política de residencia (D-10), alternativa de PEP y su costo (D-16) y conectividad híbrida (D-17).
- Validación de esta versión por la Coordinación General de TIC y consolidación con el borrador de requerimientos que prepara el Ministerio.
- Emisión del memorando a las áreas para obtener el inventario de aplicativos, tipos de usuario, roles, perfiles y atributos mínimos (D-12).
- Evaluación y recomendación del mecanismo de identidad ciudadana con su costo por tipo de usuario (D-02, BR-01, BR-10).
- ~~Actualización del Documento de Arquitectura sin Active Directory y con el sistema de permisos como componente independiente (D-04).~~
- Formalización de las dos aplicaciones legadas y de los niveles de servicio (D-03, D-06).
- Habilitación, por parte de MINEDEC, de las cuentas de prueba en Cloud Identity y de la unidad organizativa de pruebas para el equipo de desarrollo (D-15).

Anexo A. Requerimientos fuera de la línea base

Requerimientos retirados de la línea base. En la versión 0.4 se retira el siguiente; los retirados en las versiones 0.2 y 0.3 se detallan en esas versiones del documento.

Código	Requerimiento	Motivo del retiro	Versión
RF-INT-02	Refactorización de la aplicación SIEE	Depende de la selección formal de las aplicaciones (D-03); la integración de cualquier aplicación la cubre RF-INT-03 con el módulo de integración de referencia de su stack.	0.4

Anexo B. Cambios de la versión 0.4

Trazabilidad entre los hallazgos del Documento de Arquitectura de Solución SSO y los cambios de esta versión.

Hallazgo de la arquitectura	Requerimientos y decisiones	Cambio
Patrones de integración: nativo (aplicaciones de C2.3 y nuevas) y perimetral con PEP	RF-INT-01 · RF-INT-03 · RF-INT-10 (nuevo)	Se ajustan RF-INT-01 y RF-INT-03 y se agrega la integración perimetral
OIDC como protocolo principal (Authorization Code + PKCE S256) y SAML 2.0 como alternativo	RF-AUT-02 · RF-AUT-04 · RF-AUT-05	Se precisan los flujos y el contenido de la aserción SAML
El correo inicia sesión; la cédula identifica a la persona y la devuelve Sistema de Autenticación Centralizado SSO	RF-GI-11 · RF-AUZ-04 · RF-AUZ-13	La identificación, los roles y el ámbito ya no viajan en la aserción
Sistema de Autenticación Centralizado SSO es de solo lectura sobre Workspace	RF-GI-05 · RNF-REN-06	Las altas se hacen en Cloud Identity y Sistema de Autenticación Centralizado SSO las sincroniza
Revocación por revalidación (TTL de 300 segundos)	RF-GI-06	Se agrega la ventana de revocación
Google no implementa el cierre de sesión único	RF-AUT-06 · BR-16 · D-11	El cierre coordinado se resuelve con revalidación
Credencial por aplicación (OAuth 2.0 client credentials) y credencial de plataforma del PEP	RF-AUZ-12 · RNF-SEG-04 · RNF-INT-01	Se agregan la autenticación ante Sistema de Autenticación Centralizado SSO y la custodia por hash
Publicación desde la consola con Infrastructure Manager y catálogo de rutas	RF-AUZ-03 · RF-ADM-01 · RF-ADM-08 (nuevo) · RF-AUZ-17 (nuevo) · RNF-SEG-05 · RNF-MAN-03	Se agregan la publicación y el catálogo de rutas
Red y perímetro: cierre de red, fail-close y conexión híbrida	RNF-SEG-09, RNF-SEG-10 y RNF-DIS-05 (nuevos) · RF-INT-09 · BR-19 · D-17	Se agregan los requerimientos de red
El módulo de integración corre dentro de cada aplicación	RNF-REN-05	Se precisa qué componentes escalan

Hallazgo de la arquitectura	Requerimientos y decisiones	Cambio
Estructura sin «sede»: ámbito por atributos	RF-GI-13 · RF-AUZ-02 · D-05	Se resuelve D-05
Sistema de permisos a medida: Sistema de Autenticación Centralizado SSO	D-04 · 1.2	Se resuelve D-04 y se nombra la plataforma
Dominios, tenants y accesos para la sincronización por definir	RF-GI-01 · RF-AUT-01 · BR-20 · D-20 · D-21	Se corrige el dominio único y se agregan las decisiones
Selección de las aplicaciones de C2.3 sin formalizar	RF-INT-02 (retirado) · BR-12	Se retira RF-INT-02 y se quita la mención de candidatas
Alternativas de PEP; la alternativa basada solo en IAP se descartó	D-16 · BR-10	Se agregan la decisión y el costo
Subdominio de publicación y responsables de los pasos externos	D-18 · D-19	Se agregan las decisiones